# CyberRiskGuardian Assessment Kit

## Assignment briefs, rubrics and self-checks — Education Package 2.1.2

Marc-André Léger, PhD

November 2026

## Contents

1 How to use this kit ..... 2

2 The 0–10 scale ..... 2

2.1 How the score is calculated ..... 3

3 Six checks applied to every assignment ..... 4

4 A1 — Cybersecurity risk assessment (team) ..... 4

4.1 Brief ..... 4

4.2 Deliverables ..... 5

4.3 Rubric ..... 5

4.4 Self-check before you submit ..... 6

4.5 Tips ..... 6

5 A2 — Information security policy: Identity and Access Management (team) ..... 7

5.1 Brief ..... 7

5.2 Rubric ..... 7

5.3 Self-check ..... 8

6 A3 — Risk-based cybersecurity audit plan (individual) ..... 8

6.1 Brief ..... 8

6.2 Rubric ..... 9

6.3 Self-check ..... 10

7 Shorter formats ..... 10

7.1 Lab portfolio (individual, pass/fail or 10%) ..... 10

7.2 Individual scenario paper (individual, 2–3 pages) ..... 10

7.3 In-class quick-scan challenge (teams, 75 minutes) ..... 10

7.4 Exam essay (individual, in person, no AI)..... 10

8 Peer-review form for team assignments..... 11

9 Generative AI acknowledgement..... 11

# 1 How to use this kit

This kit gives instructors ready-to-adapt assignment briefs and rubrics for courses that use CyberRiskGuardian, and gives students the criteria their work will be judged on. It is based on the assessment design of an undergraduate cybersecurity course, generalized so that any institution can use it.

**For instructors.** Replace the bracketed items — [due week], [weight], [page limit], [submission platform], [allowed / not allowed] — with your own. Keep the criteria and the descriptors: they are what makes grading consistent between sections and teaching assistants. Your course outline and assignment instructions remain the authoritative source; say so to students.

**For students.** Read the rubric before you start, not after. Every criterion tells you what a strong submission shows. Use the self-check list before you submit.

The kit contains:

1. The 0–10 grading scale and how an assignment score is calculated.
2. Six checks applied to every assignment.
3. Three main assignments: **A1** risk assessment (team), **A2** security policy (team), **A3** risk-based audit plan (individual).
4. Four shorter formats: lab portfolio, individual scenario paper, in-class quick-scan challenge, exam essay.
5. A peer-review form for team work and the generative AI acknowledgement.

The lab answer keys, a graded quiz bank, rubric calibration examples and a bank of feedback comments are in the Educator Edition.

# 2 The 0–10 scale

Every criterion of every assignment is scored from 0 to 10. A **10** represents exceptional achievement of all criteria; a **6** represents satisfactory achievement of the essential requirements.

| Score | Level | Description |
|---|---|---|
| 10 | Exceptional | Fully satisfies or exceeds all requirements, with exceptional understanding, rigorous analysis, accuracy, originality and outstanding presentation |
| 9 | Excellent | All requirements to a very high standard; only negligible shortcomings |
| 8 | Very good | Nearly all requirements, solid understanding and effective analysis; a few minor weaknesses |
| 7 | Good | Most requirements, good understanding and generally sound execution; some weaknesses or limited depth |
| 6 | Satisfactory | The essential requirements, adequate understanding; noticeable weaknesses, |

| Score | Level | Description |
|---|---|---|
| | | omissions or limited analysis |
| 5 | Marginal | Partially meets the requirements; significant omissions, inaccuracies or weaknesses |
| 4 | Below expectations | Only a limited number of requirements; insufficient understanding or substantial errors |
| 3 | Poor | Fails most requirements; major conceptual misunderstandings |
| 2 | Very poor | Addresses only a small portion; serious deficiencies |
| 1 | Minimal effort | Negligible relevant content |
| 0 | No assessable work | No submission, or nothing relevant to assess |

## 2.1 How the score is calculated

1. Each assignment has six to eight criteria, each with a weight.
2. The assignment score is the weighted average of the criterion scores, out of 10.
3. Some requirements **cap** a criterion: if a required element is missing or a number is invented, that criterion's score is limited however well the rest is done.
4. The score × 10 gives a percentage. Any late penalty set by the course is then applied to the earned mark.
5. For every criterion below 10, the student receives the main shortcomings and what would earn a higher score.

**Worked example (A1, six criteria):**

| Criterion | Weight | Score | Weight × score |
|---|---|---|---|
| Scenario S1 — relevance and originality | 20% | 8 | 1.6 |
| Risk analysis tables — completeness and precision | 20% | 7 | 1.4 |
| Mitigation measures — appropriateness | 20% | 6 | 1.2 |
| Memorandum — clarity and argumentation | 20% | 8 | 1.6 |
| Presentation and editorial quality | 10% | 9 | 0.9 |
| Synthesis and strategic conclusions | 10% | 7 | 0.7 |
| **Assignment score** | | | **7.4 / 10 = 74%** |

**Grading principles:** consistency (the same descriptors for everyone), evidence-based assessment (marks reflect what the work demonstrates, not effort), proportionality (minor presentation issues do not outweigh substantial achievement unless presentation is itself the criterion) and feedback for every criterion below 10.

# 3 Six checks applied to every assignment

| # | Check | What it means |
|---|---|---|
| 1 | Completeness | Every required deliverable and section is present, within the page limits |
| 2 | Fidelity to the case and evidence | Facts come from the case and credible cited sources; each claim is labelled as fact, inference, estimate, assumption or recommendation; no case facts are invented |
| 3 | Correct use of models and frameworks | CyberRiskGuardian, CVSS, NIST CSF 2.0, ISO/IEC 27001 and 27002:2022, COBIT 2019 and audit standards are applied to the case, not just named |
| 4 | Numerical and technical accuracy | Numbers are in valid ranges, can be recomputed and agree across every file; calculations are shown |
| 5 | Actionable recommendations | Specific, prioritized, costed, with trade-offs, ownership, residual risk and assumptions |
| 6 | Professionalism | Title page with every author and ID, consistent citations (APA 7 or IEEE), executive-level language, an explicit generative AI acknowledgement |

**Check every identifier.** Framework numbering changes between versions: NIST CSF 1.1 and 2.0 use different subcategory codes; ISO/IEC 27001:2013 and 2022 number their controls differently. A code that does not exist, or is used for the wrong purpose, counts against the accuracy of the criterion where it appears. Generative AI tools frequently invent such codes.

**Common quality problems.** Repeating case facts without analysis · presenting an AI-generated number, CVSS vector or control mapping as verified · choosing a solution first and inventing risks to justify it · naming a framework without linking it to evidence · copying templates or worked examples without adapting them · "control dumping" (many controls without saying which risk each addresses, what it adds and what it costs) · numbers that disagree between files · treating CVSS as the risk · recommendations without cost, trade-offs, owner or sequence.

# 4 A1 — Cybersecurity risk assessment (team)

**Team of 3–4 · Due [week] · [Weight, e.g. 20%] of the course grade**

## 4.1 Brief

Your team acts as cybersecurity consultants to the organization described in your assigned business case. Perform a scenario-based cybersecurity risk assessment with CyberRiskGuardian and recommend a prioritized portfolio of risk treatments to management.

1. **Create one original risk scenario (S1)** using the course scenario model. It must be distinct from every scenario supplied in your case and in the course guides.
2. **Analyze ten scenarios** — S1 plus nine supplied by your case or selected by your team from its scenario library (S2–S10) — with the six CRG parameters and a CVSS v4.0 score for each (v3.1 accepted if used consistently; keep the vector).
3. **Set the organization's risk appetite**, using the tolerance the case states or a justified alternative.

4. **Select treatment measures** to bring unacceptable risk to a tolerable level, and compare residual risk with tolerated risk.

Use the case your instructor assigns. MediBec and CanaRetail are practice cases whose solutions are public; they are not used for this assignment.

**Virtual consultant (desktop track): [allowed / not allowed] for this assignment.** If it is allowed, declare it in your AI acknowledgement and attach the conversations you relied on (Tools → Virtual consultant → *History* → *Export as Markdown*). If it is not, set *Virtual consultant* and *Virtual consultant — parameter critique* to **Off** in Settings → AI — local & remote before you start.

## 4.2 Deliverables

1. The completed CyberRiskGuardian file: the workbook (Analyse, S1–S10, M1–M10), the desktop workspace export, or the assessment JSON — as your instructor specifies.
2. A **one-page executive memorandum** to management.
3. A **two-page recommendation document** justifying the portfolio on cost-effectiveness, risk reduction, industry standards (ISO/IEC 27001/27002 or NIST CSF 2.0), risk tolerance and budget.
4. The **original scenario S1** written with the course model (1–3 pages).

Appendices are allowed and do not count in the page limits.

## 4.3 Rubric

| Criterion | Weight | What a strong submission (9–10) shows | Satisfactory (6) | Caps |
|---|---|---|---|---|
| **Relevance and originality of S1** | 20% | A complete causal statement grounded in verifiable case facts; distinct from S2–S10 and from every example; primary and supporting assets, owner, existing controls and evidence identified; assumptions labelled; a defensible technical vulnerability for CVSS where CVSS applies | A recognizable causal chain with some case grounding; some elements generic | A threat label instead of a scenario: max 4. A copy or close variant of a supplied scenario: max 3 |
| **Completeness and precision of the risk analysis** | 20% | All ten scenarios complete; every value in range; $\delta m \geq \delta e$; $\theta > 0$; CVSS 0–10 with the vector kept; one horizon; file recalculated; rationale for each number; numbers agree with the memo | All scenarios present with values; thin rationale; minor range or consistency errors | Invented or unexplained numbers on several scenarios: max 5. Workbook not recalculated: max 6 |
| **Appropriateness of the mitigation measures** | 20% | Controls tied to steps in the causal chain and incremental to existing controls; costed on one horizon with shared costs counted once; reductions justified, none above 1.0; feasible for this organization; no control the | Reasonable controls, partly justified; some generic items; costs approximate | Reductions above 1 or a package that reduces only one dimension without comment: max 5 |

| Criterion | Weight | What a strong submission (9–10) shows | Satisfactory (6) | Caps |
|---|---|---|---|---|
| | | case says already exists | | |
| **Clarity and argumentation of the memorandum** | 20% | Decision first; which scenarios exceed tolerance; recommended portfolio; cost against budget; residual risk against tolerance; key uncertainties and next steps; one page; consistent with the workbook | Clear but descriptive; the decision is present but not leading; some figures missing | Figures that contradict the workbook: max 5 |
| **Presentation standards and editorial quality** | 10% | Professional format, consistent terminology, correct citations, complete title page, explicit AI statement, proofread | Generally tidy; a few lapses | No AI statement: max 5 |
| **Synthesis and strategic conclusions** | 10% | A portfolio-level view: total cost against the budget context, scenarios within tolerance after treatment, priorities and sequencing, quick wins, which residual risks are formally accepted and by whom | Some prioritization; limited portfolio view | — |

## 4.4 Self-check before you submit

- ☐ S1 is a full causal statement with case evidence and differs from S2–S10.
- ☐ All ten scenarios are complete; ranges are respected; θ is never zero; vectors are kept; one CVSS version is used.
- ☐ The file has been recalculated and the memo and recommendation match it to the unit.
- ☐ The appetite is stated and justified against the case tolerance; residual risk is compared with tolerated risk.
- ☐ Each measure is tied to a scenario and a step of its chain, costed on one horizon and justified; shared measures are counted once.
- ☐ The memo is one page and leads with the decision; the recommendation is two pages.
- ☐ The three markers (**Analytical estimate — validation required**, **Information gap — organizational validation required**, **Management decision required**) appear where they belong; the title page, citations and AI statement are complete.

## 4.5 Tips

- Keep the probability that the threat is present separate from the probability that exploitation succeeds.
- Give a short rationale and evidence for every number, and say which two or three values are the most uncertain.
- CVSS scores one defined technical vulnerability, not a whole scenario.

- The workbook (v2-6) validates inputs and lists problems in its Checks column (AC); still read estimated and tolerated risk numerically rather than by cell colour, replace the 0.5 appetite placeholder, and keep each CVSS vector next to its score.
- In the memo, say how many scenarios are above tolerance before and after treatment, what the portfolio costs and what risk remains. Do not restate tables.

# 5 A2 — Information security policy: Identity and Access Management (team)

**Team of 3–4 · Due [week] · [Weight, e.g. 10%]**

## 5.1 Brief

Translate your understanding of the organization's risks into an actionable governance document: one formal **Identity and Access Management (IAM) policy**, formatted for executive approval, in language that bridges technical operations and business governance. Anchor it in your case and in your A1 results. It must describe roles and responsibilities, exception handling, the consequences of non-compliance, and how compliance is monitored and measured.

Recommended format: one focused policy of about 3–5 pages, plus a short management rationale and a hierarchy map showing which standards, guidelines and procedures sit beneath it.

**Evidence from the desktop application.** If your workspace for the case holds Identity & access management (IAM/PAM) registers (Lab 13), you may use them as evidence: cite the indicator (for example CRG-18 Privileged MFA coverage) or the finding with its E-number, and say whether the counts are confirmed or inferred. Registers hold counts per population, never names. They support your argument; they do not replace the case facts, and the rubric is the same whichever track you use.

**Virtual consultant (desktop track): [allowed / not allowed] for this assignment.** If it is allowed, declare it in your AI acknowledgement and attach the conversations you relied on (Tools → Virtual consultant → *History* → *Export as Markdown*). If it is not, set *Virtual consultant* and *Virtual consultant — parameter critique* to **Off** in Settings → AI — local & remote before you start.

## 5.2 Rubric

| Criterion | Weight | What a strong submission shows |
|---|---|---|
| Business and risk alignment | 15 % | The IAM risk justified with case facts and A1 evidence; "the organization needs this policy because **, *and it will be successful when*** " |
| Framework and obligation alignment | 10 % | NIST CSF 2.0 and ISO/IEC 27001/27002:2022 used selectively and accurately as a crosswalk; legal or contractual obligations named from authoritative sources; no invented legal duties |
| Document hierarchy | 10 % | Policy separated from standards, guidelines and procedures; a hierarchy map; technical values placed in a named standard or procedure |
| Structure and completeness | 15 % | Document control block (title, ID, version, status, owner, approver, dates, classification); purpose; scope; definitions; numbered statements; roles; |

| Criterion | Weight | What a strong submission shows |
|---|---|---|
| | | exceptions; compliance monitoring; violations; related documents; review |
| Policy statement quality | 20 % | Each statement names an actor, uses **must** or **must not**, states an outcome, object and condition; active voice; testable; numbered; addressed to whoever can actually perform it |
| Implementation and monitoring | 15 % | Evidence for each significant statement; KPIs with target, owner, data source, frequency, reporting route and corrective action; communication plan; acknowledgement; effective date and transition; review triggers |
| Professional presentation | 10 % | Concise, readable, consistently numbered, correctly referenced, proofread; title page; AI statement |
| Original analysis | 5% | Judgement specific to this organization; alternatives compared |

**Normative vocabulary.** Use one vocabulary consistently: **must** for obligations, **must not** for prohibitions, **should** for a recommendation that allows justified exceptions, **may** for a permission. Avoid “regularly”, “promptly”, “appropriate” and “where possible” unless a standard defines them.

**What an IAM policy normally covers.** Identity lifecycle (joiners, movers, leavers); authentication and MFA, with stronger options for privileged and remote access; service and non-human accounts; third-party access; emergency (break-glass) access; privileged access management and logging; periodic access reviews; separation of duties; remote and mobile access; offboarding timelines; exceptions with risk acceptance, expiry and compensating controls.

**Desktop track.** ISP management → *Policy library* → *Access control and authentication* → *Create from the template* gives a draft whose statements carry an identifier, a modality and their ISO/IEC 27002:2022 and NIST CSF 2.0 controls. Treat it as a starting point: the grade is for your adaptation to the case.

### 5.3 Self-check

- ☐ The policy is about IAM, justified with case evidence and A1 results, and says what success looks like.
- ☐ A document control block and a hierarchy map are present.
- ☐ Statements are numbered, use one normative vocabulary, and say who must do what in a way that can be checked.
- ☐ Roles, exceptions, monitoring, violations and enforcement, and review are present.
- ☐ KPIs have targets, owners, data sources and frequencies.
- ☐ Framework references are current and accurate; no invented obligations.

## 6 A3 — Risk-based cybersecurity audit plan (individual)

**Individual · Due [week] · [Weight, e.g. 10%]**

### 6.1 Brief

Write a formal, risk-based cybersecurity audit plan for the case organization, guided by the internal audit framework covered in class, COBIT 2019 and the IIA’s GTAG guidance on developing the IT audit plan. Map the

critical IT assets, prioritize audit effort where cyber risk is highest, define the audit scope and design control testing: objectives, specific controls and procedures such as configuration reviews, data analysis and computer-assisted audit tools and techniques (CAATTs).

Recommended structure: executive summary; organization and audit context; audit universe; risk method and ranking; annual audit plan; multi-year roadmap; detailed engagement plan with work program; control-testing method; reporting and follow-up; references and appendices.

**Virtual consultant (desktop track): [allowed / not allowed] for this assignment.** If it is allowed, declare it in your AI acknowledgement and attach the conversations you relied on (Tools → Virtual consultant → *History* → *Export as Markdown*). If it is not, set *Virtual consultant* and *Virtual consultant — parameter critique* to **Off** in Settings → AI — local & remote before you start.

## 6.2 Rubric

| Criterion | Weight | What a strong submission shows |
|---|---|---|
| Business alignment and context | 10 % | Starts from objectives, critical services and business risks; mandate, audience, independence and approval authority clear; case facts used, assumptions labelled |
| Audit universe | 15 % | About 5–10 auditable entities by domain (governance, process, information, people, technology, third parties, resilience, change), each with an owner, a scope boundary and a link to a service or risk — not a hardware inventory |
| Risk method and ranking | 20 % | Factors and weights totalling 100%, rating anchors, a formula, evidence and rationale for each rating, priority tiers, documented overrides, recomputable arithmetic; A1 results used as an input without treating CVSS or the CRG ratio as the whole priority |
| Annual portfolio, roadmap and resources | 20 % | Engagements selected, deferred, combined or relied upon, with reasons; high-risk omissions disclosed; hours that add up, with contingency and follow-up; competencies; a three-year roadmap; other assurance evaluated |
| Detailed engagement plan and work program | 25 % | Objectives, scope, exclusions, criteria; a risk-control matrix with a test of design and a test of operating effectiveness per key control; evidence methods; sampling (population, period, unit, method, size); CAATTs tied to specific risks with data-validation steps |
| Reporting, follow-up and dynamism | 5% | Finding structure (criteria, condition, cause, effect, recommendation, owner, due date); issue rating; follow-up validation; triggers for changing the plan |
| Professional presentation | 5% | Concise, referenced, consistent, traceable calculations; title page; AI statement |

**Desktop track.** Audit management → *Audit universe* → *Add critical and high assets not yet in the universe*; *Audit plan* scores entries from inherent risk, time since the last audit and the residual risk of their scenarios, read from the engine. *Procedures · SP 800-53A* shows the assessment objectives of a control. CRGO's work programmes are illustrative, not a validated audit methodology.

### 6.3 Self-check

- ☐ The plan starts from business objectives; the audit universe is structured and its size explained.
- ☐ The scoring method, weights (100%), anchors and arithmetic are shown, and the ranking matches the selection.
- ☐ Selected, deferred and omitted engagements are explained; hours and reserves add up.
- ☐ The engagement plan has a risk-control matrix, design and operating tests, sampling and CAATTs with data validation.
- ☐ Reporting, follow-up and plan-change triggers are described.
- ☐ If you reuse your team's A1 results, they are cited; if you audit a control your team recommended, independence is addressed.

## 7 Shorter formats

### 7.1 Lab portfolio (individual, pass/fail or 10%)

Students submit the deliverables of Labs 1 to 10 of the Student Lab Workbook, one PDF, with a one-page reflection: *Which estimate changed most between your first draft and the final version, and why?* Grade on completeness (50%), use of the three markers (25%) and the reflection (25%).

### 7.2 Individual scenario paper (individual, 2–3 pages)

Write one original scenario for an assigned case, quantify it, score its CVSS vector, calculate estimated, tolerated and residual risk for one treatment package, and argue in one page whether management should mitigate, transfer, avoid or accept.

| Criterion | Weight |
|---|---|
| Causal chain and case grounding | 30% |
| Parameters, rationale and CVSS | 30% |
| Calculation and interpretation against tolerance | 20% |
| Recommendation and decision required | 20% |

### 7.3 In-class quick-scan challenge (teams, 75 minutes)

Each team receives a two-page organization profile it has not seen. Using `/crg-quick-scan` (Claude track) or *Batch scenarios* (desktop track), the team produces 20 candidates, selects ten, and presents a one-slide verdict table. The class then votes on the scenario that is best supported by the profile and the one that is least supported. Grade the defence of choices, not the AI output.

### 7.4 Exam essay (individual, in person, no AI)

A business case is distributed before the exam; students may prepare scenarios in advance, with AI if they disclose it, and bring them to the exam. During the exam, students answer one or two essay questions (for example, rank three scenarios and justify the ranking; recommend a cybersecurity budget against the stated appetite; explain to the board why a scenario remains above tolerance after treatment). Each criterion is scored on the 0–10 scale. The Educator Edition contains an exam case and blueprint.

# 8 Peer-review form for team assignments

Each team member completes this form confidentially. The instructor may use it to adjust individual marks within a stated range (for example ±10%).

| Team member | Contribution (describe) | Reliability (1–5) | Quality (1–5) | Collaboration (1–5) |
|---|---|---|---|---|
| | | | | |
| | | | | |
| | | | | |

*Who verified the numbers against the workbook before submission?* _____

*Who checked the AI-generated content against the case and primary sources?* _____

# 9 Generative AI acknowledgement

Include near the title page or in an appendix:

> *I/We used [tool name and version — for example the CyberRiskGuardian Virtual consultant, with the model shown in its decision log] to [purpose: for example brainstorm risk scenarios, propose parameter rationales, check grammar, summarize a source]. I/We verified all outputs against the case and against primary sources, recomputed every number with the CyberRiskGuardian engine, edited the text, and take responsibility for all content. [Or: No generative AI tools were used in this assignment.]*

**Rules.** Generative AI is allowed on assignments with this acknowledgement, unless the brief says otherwise, and is not allowed during the exam. The CyberRiskGuardian Virtual consultant is an AI tool like any other: each brief says whether it may be used. You are responsible for everything you submit. A fabricated or untraceable source is both an evidence problem and an academic-integrity concern. Do not paste confidential material into an external AI service unless you are authorized to.

*© 2026 Marc-André Léger. Licensed under CC BY-NC 4.0. Adapted from the author's student assignment guide for an undergraduate cybersecurity course.*